J26-CS-323 · IT4010 RESEARCH PROJECT · PROGRESS PRESENTATION 1

Simulated Evidence Pack

SIM-CREDIT-SCORING-01 — an AI credit-scoring system at a fictional Sri Lankan bank

The shared “initial data” for all four components: the system being assessed, the evidence each component scores, the test-case evidence states, and the public sources every requirement is traced to.

Item	Detail
Project	A Unified Cyber Governance and Digital Trust Framework for Banking AI Systems
Group / panel	J26-CS-323 · Cyber Security · IAS cluster · CS-P02
Version	1.1 — for PP1, 26 October 2026
Date	24 October 2026 (sources checked 21 October 2026)
Status	**Simulated.** No real bank, customer or transaction data. Bank S and every document and finding in this pack are invented for testing the method.
Basis	Built from the four PP1 tools and the public sources listed in Section 8.
Used by	C1 Cyber Trust (EP-01–EP-18) · C2 Risk Exposure (variants V1–V4) · C3 Compliance (EV-01–EV-12) · C4 Governance Decision (scenarios S1–S6)

Contents

1. What this pack is, and what it is not
2. The simulated system
3. Deployment variants (C2)
4. Evidence register
5. Test-case evidence states
6. Expert judgements — current status
7. Limitations
8. Source register
9. Corrections made after checking the sources

1. What this pack is, and what it is not

- **It is** the test subject for our method: one simulated AI credit-scoring system, described the way a bank would document it, with the evidence an assessor would ask to see.
- **It is** traceable: every evidence item states which public standard or regulation asks for it (Section 4), and each source was looked up on 21 October 2026 and its check status is shown in Section 8.
- **It is** the single source of the test cases already built into the four tools (Section 5). The tools and this pack use the same codes.
- **It is not** real data. Bank S does not exist. Findings such as "all 50 sampled outputs carry reason codes" describe an imagined evidence state, not a measurement.
- **It is not** expert-validated yet. No expert judgements have been collected (Section 6). After PP1, bank practitioners will be asked whether the system and its evidence are realistic.

> Why simulated? We assess the AI system, not its customers, so no customer data is needed. A real bank's AI controls and weaknesses are confidential security information that a bank would not release to a student project.

2. The simulated system

2.1 System profile

Attribute	Value (simulated)
Asset ID	SIM-CREDIT-SCORING-01
Operator	"Bank S" — a fictional mid-sized licensed commercial bank in Sri Lanka
Business use	Credit decisions on unsecured retail personal loans
What the AI does	Estimates each applicant's probability of default within 12 months and turns it into a recommendation: Approve, Refer to an officer, or Decline
Model type	Gradient-boosted decision-tree classifier, retrained quarterly (in-house in variants V1–V2; vendor or third-party components in V3–V4)
Inputs	42 features from the application, the bank's own loan and account history, and a credit-bureau feed
Explanations	Per-decision reason codes produced with SHAP (Shapley additive explanations)
Decision owner	Head of Credit Risk (accountable owner, 1st line)
Why it matters	Credit scoring of natural persons is listed as high-risk in the EU AI Act, Annex III point 5(b). Bank S is not in the EU, but this shows how regulators rate this use.

2.2 The four layers assessed

Layer	What it contains at Bank S	Main evidence
L1 Training and reference data	Five years of internal loan history, credit-bureau records, data pipeline and feature store	Data sheet, data-quality report, bias test report, DPIA
L2 AI model	The scoring model, its training code, retraining pipeline and model registry	Model card, validation report, robustness tests, access review
L3 Inputs and interfaces	Branch application form, online application (V3–V4), bureau API, integrations with the core banking system	Input-validation tests, integration credential list, access review
L4 Outputs and decisions	Score, recommendation, reason codes, adverse-action letters, decision log, human overrides	Decision log, override log, customer notice, adverse-action letter

2.3 Roles (Three Lines Model)

Taken from the owner register in the C4 tool. The people are fictional. C4 assigns every action to these roles (RACI) and checks that nobody reviews or audits their own work.

Line	Role at Bank S	Person (fictional)	Accountability in C4
1st	Head of Retail Credit Analytics (model owner)	N. Perera	Accountable: Return less detail in outputs; Sanitise and verify training-data provenance; Verify vendor / pre-trained model artefacts; Bias testing across groups each release; Reason codes and adverse-action explanations; Independent model validation; Drift monitoring with alert thresholds · Responsible: AI risk register and named accountable owner
1st	Model development lead	S. Fernando	Responsible: Bias testing across groups each release; Reason codes and adverse-action explanations; Independent model validation; Drift monitoring with alert thresholds
1st	Data engineering lead	R. Silva	Responsible: Sanitise and verify training-data provenance
1st	Head of Credit Operations (business owner)	A. Jayawardena	Accountable: Human oversight and appeal procedure; AI risk register and named accountable owner
1st	Head of IT	K. Wickramasinghe	Accountable: Rate-limit and monitor model queries; Validate inputs and detect adversarial inputs; Guardrails and input filtering on the assistant; MFA and segregation on the retraining pipeline; Tamper-evident decision logging
1st	IT security operations manager	M. Bandara	Responsible: Rate-limit and monitor model queries; MFA and segregation on the retraining pipeline
1st	Lending platform application lead	D. Rathnayake	Responsible: Return less detail in outputs; Validate inputs and detect adversarial inputs; Tamper-evident decision logging
1st	Digital channels manager	T. Herath	Responsible: Guardrails and input filtering on the assistant
1st	Vendor management manager	P. Dissanayake	Responsible: Verify vendor / pre-trained model artefacts
2nd	Head of Model Risk Management	L. Gunasekara	Reviews and signs off: Return less detail in outputs; Sanitise and verify training-data provenance; Tamper-evident decision logging; Independent model validation; Drift monitoring with alert thresholds
2nd	Information security risk manager (CISO office)	H. Karunaratne	Reviews and signs off: Rate-limit and monitor model queries; Validate inputs and detect adversarial inputs; Guardrails and input filtering on the assistant; MFA and segregation on the retraining pipeline
2nd	Head of Compliance	J. Senanayake	Reviews and signs off: Bias testing across groups each release; Reason codes and adverse-action explanations; Human oversight and appeal procedure
2nd	Third-party risk manager	C. Weerasinghe	Reviews and signs off: Verify vendor / pre-trained model artefacts
2nd	Chief Risk Officer	V. Abeysekara	Reviews and signs off: AI risk register and named accountable owner · Signs Approve, Monitor and Restrict verdicts
3rd	Chief Internal Auditor	G. Ranasinghe	3rd-line assurance for every action

Line	Role at Bank S	Person (fictional)	Accountability in C4
Board	Chair, Board Integrated Risk Management Committee	W. Samarasinghe	Decides and signs a Reject verdict

2.4 Which rules apply to Bank S

Source	Status for Bank S	How the pack uses it
CBSL Banking Act Directions No. 16 of 2021 (technology risk management and resilience)	Binding on licensed banks in Sri Lanka	Context for access control, incident handling and third-party oversight. Not yet mapped clause by clause.
Personal Data Protection Act No. 9 of 2022 (Sri Lanka)	Applies to personal data; commencement of some parts is still being phased in	Context only. Commencement dates to be confirmed before it is mapped.
EU AI Act · GDPR	Apply only if Bank S serves the EU market	C3 test case TC4 switches the EU market into scope to show applicability
MAS FEAT · NIST AI RMF · NIST CSF 2.0 · ISO/IEC 42001 · FS AI RMF · SR 26-2	Voluntary or foreign good-practice benchmarks	Requirement sources for indicators and harmonised controls
MITRE ATLAS · NIST AI 100-2 E2025 · OWASP LLM Top 10 (2025)	Threat knowledge bases	Threat catalogue for C2

3. Deployment variants (C2)

C2 assesses four ways the same system could be deployed. The deployment changes which threats apply and how exposed the system is.

	V1 Internal batch scoring	V2 Branch officer tool	V3 Online customer application	V4 Chat assistant on third-party model
Channel	Overnight batch run by credit analysts	Loan officers enter applications in branch	Customers apply on web and mobile	Customer chat assistant fronts the scoring
Model source	In-house	In-house	Vendor pre-trained component	Third-party foundation model
Output returned	decision	score	score	probability
Data	Curated internal loan history	Internal history + credit-bureau feed	Internal history + bureau + external feeds	Internal + bureau + unverified external feeds
Outside parties can query it	No	No	Yes	Yes
Applicant controls inputs	No	Yes	Yes	Yes
External feeds / integrations	No / No	Yes / No	Yes / Yes	Yes / Yes
Generative component	No	No	No	Yes
Data sensitivity (weight 0.25)	4 — Personal financial data	4 — Personal financial data	5 — Personal financial + bureau data, large scale	5 — Personal financial + bureau data, large scale
Attack surface (weight 0.22)	1 — No external inputs	3 — Staff enter applicant data	4 — Applicants submit data online	5 — Open conversational channel
Model exposure (weight 0.2)	1 — Decision only, internal	2 — Score shown to staff	4 — Score + reasons externally, rate-limited	5 — Probability + explanation, no rate limit
Access exposure (weight 0.18)	2 — Few systems, MFA	3 — Several systems, shared retraining access	3 — Several systems, shared retraining access	4 — Many systems, weak segregation
Third-party & integration (weight 0.15)	1 — None	2 — Internal integrations only	4 — Vendor model component	5 — Third-party foundation model, unverified

	V1 Internal batch scoring	V2 Branch officer tool	V3 Online customer application	V4 Chat assistant on third-party model
Expected band	**Low**	**Medium**	**High**	**Critical**

4. Evidence register

Each evidence item is a document Bank S would hold. C1 rates its 18 indicators against items EP-01 to EP-18. C3 rates its 12 harmonised controls against items EV-01 to EV-12. Where both components look at the same document, the last column of 4.1 cross-references it.

4.1 C1 trust indicators (EP-01 – EP-18)

Code	Dimension · indicator	Evidence document	What "Full" requires	Source basis (checked)	Same doc.
EP-01	Transparency Model documentation / model card exists	Model card	Complete, versioned model card: purpose, inputs, limitations, owner	EU AI Act Art. 11 · NIST AI RMF MEASURE 2.9 · SR 26-2 §VI Documentation	EV-03
EP-02	Transparency Training data sources & features disclosed	Data sheet	All sources, features and lineage documented	EU AI Act Art. 10 · MAS FEAT P3 · ISO/IEC 42001 Annex A.7*	EV-02
EP-03	Transparency Decision logic communicated to stakeholders	Customer disclosure notice	Plain-language explanation of the main decision factors	MAS FEAT P12 · EU AI Act Art. 26(11) · GDPR Art. 13–14	EV-05
EP-04	Explainability Each decision produces a reason/explanation	Sample decision outputs	Every decision carries its top reason codes	MAS FEAT P13 · NIST AI RMF MEASURE 2.9	—
EP-05	Explainability Explanation method is documented & validated	Explainability method report	Method documented and validated against model behaviour	NIST AI RMF MEASURE 2.9 · SR 26-2 §V (conceptual soundness, interpretability)	—
EP-06	Explainability Adverse-action reasons given to customers	Adverse-action letter	Specific reasons the customer can understand	MAS FEAT P13–P14 · EU AI Act Art. 86 · GDPR Art. 22	—
EP-07	Accountability A named role owns the model	Model ownership register	A named accountable role has signed off	MAS FEAT P7–P8 · NIST AI RMF GOVERN 2.1 · SR 26-2 §VI Roles and Responsibilities	EV-12
EP-08	Accountability Human oversight / override process exists	Override procedure & log	Documented procedure; overrides logged and reviewed	MAS FEAT P10–P11 · EU AI Act Art. 14 · NIST AI RMF MANAGE 4.1 (appeal and override)	EV-06
EP-09	Accountability Incident & escalation process defined	AI incident procedure	AI-specific incident process with an escalation path	NIST AI RMF MANAGE 4.1 (incident response) · NIST CSF 2.0 RESPOND	—
EP-10	Auditability Decisions logged with model version & inputs	Decision log extract	Inputs, output, model version and timestamp logged	EU AI Act Art. 12 · NIST CSF 2.0 PR.PS	EV-04
EP-11	Auditability Logs retained & tamper-evident per policy	Log retention policy	Retention defined and logs tamper-evident (write-once or hashed)	EU AI Act Art. 26(6) (keep logs ≥ 6 months) · GDPR Art. 5(1)(e) · NIST CSF 2.0 PR.PS	EV-04
EP-12	Auditability Independent review / audit process exists	Validation / audit report	Independent validation or internal audit (2nd/3rd line)	SR 26-2 §III effective challenge, §V validation · IIA Three Lines Model (2026)	EV-09
EP-13	Fairness Bias testing across protected groups	Bias test report	Tested across relevant groups and repeated on retraining	MAS FEAT P1, P3 · NIST AI RMF MEASURE 2.11 · EU AI Act Art. 10(2)(f)	EV-08
EP-14	Fairness Fairness metrics & thresholds defined	Fairness policy	Metrics with approved thresholds	MAS FEAT P1–P2 · NIST AI RMF MEASURE 2.11	EV-08

Code	Dimension · indicator	Evidence document	What "Full" requires	Source basis (checked)	Same doc.
EP-15	Fairness Remediation process for detected bias	Bias remediation record	Documented process with tracked actions	MAS FEAT P3–P4 · EU AI Act Art. 10(2)(g)	—
EP-16	Robustness Performance monitored for drift	Drift monitoring report	Scheduled monitoring with alert thresholds	MAS FEAT P4 · NIST AI RMF MANAGE 4.1 · SR 26-2 §V ongoing monitoring	—
EP-17	Robustness Adversarial / data-quality testing done	Robustness test report	Data-quality plus adversarial / stress testing	EU AI Act Art. 15(5) · NIST AI RMF MEASURE 2.7 · NIST AI 100-2 E2025 · ATLAS AML.T0015	EV-07
EP-18	Robustness Fallback / safe-mode on failure defined	Fallback procedure	Documented and tested fallback (e.g. manual underwriting)	EU AI Act Art. 15(4) (fail-safe plans) · NIST AI RMF MANAGE 4.1 (recovery)	—

* ISO/IEC 42001 is a paid standard. Its Annex A control areas were checked against a secondary listing; the standard's own text has not been read.

4.2 C3 harmonised controls (EV-01 – EV-12)

Code	Control	Evidence document	What "Met" looks like	Owner	Source links as used in the C3 tool · check result
EV-01	HC-01 AI risk-management process L1, L2, L3, L4 · weight 3	AI risk register and risk assessment	risk register reviewed and approved	Model owner (1st line)	EU AI Act Art. 9 Risk management system *(Equivalent)* ✓ ISO/IEC 42001 Annex A.5 Assessing impacts of AI systems *(Overlapping)* * control area from a secondary listing (paid standard) NIST AI RMF GOVERN / MAP / MANAGE *(Overlapping)* ✓ FS AI RMF AI risk-management practices *(Overlapping)* ✓ SR 26-2 §VI Governance and controls *(Complementary)* ✓
EV-02	HC-02 Training-data governance and quality L1 · weight 3	Data sheet and data-quality report	data sheet plus quality report	Data engineering lead (1st line)	EU AI Act Art. 10 Data and data governance *(Equivalent)* ✓ ISO/IEC 42001 Annex A.7 Data for AI systems *(Equivalent)* * control area from a secondary listing (paid standard) NIST AI RMF MAP / MEASURE *(Overlapping)* ✓ GDPR Art. 5(1)(c)–(d) Minimisation, accuracy *(Complementary)* ✓
EV-03	HC-03 Technical documentation and model inventory L2 · weight 2	Model card and inventory entry	complete model card, in inventory	Model owner (1st line)	EU AI Act Art. 11 Technical documentation *(Equivalent)* ✓ SR 26-2 §VI Model inventory; Documentation *(Overlapping)* ✓ ISO/IEC 42001 Annex A.6 AI system life cycle *(Overlapping)* * control area from a secondary listing (paid standard)
EV-04	HC-04 Decision logging and record-keeping L4 · weight 2	Decision-log extract and retention policy	full decision log, retained	IT operations (1st line)	EU AI Act Art. 12 Record-keeping *(Equivalent)* ✓ NIST CSF 2.0 PR.PS Platform security (logging) *(Overlapping)* ✓ SR 26-2 §VI Documentation *(Complementary)* ✓ GDPR Art. 5(1)(e) Storage limitation *(Conflicting)* ✓
EV-05	HC-05 Notice of AI use to customers L4 · weight 2	Customer disclosure notice	notice explains the key factors	Retail credit product owner (1st line)	EU AI Act Art. 26(11) Informing affected persons; Art. 86 Right to explanation *(Overlapping)* ✓ GDPR Art. 13–14 Information to data subjects *(Overlapping)* ✓ MAS FEAT Transparency principles *(Overlapping)* ✓

Code	Control	Evidence document	What "Met" looks like	Owner	Source links as used in the C3 tool · check result
EV-06	HC-06 Human oversight and right to contest L4 · weight 3	Override procedure and appeal log	procedure, logged and reviewed	Head of credit operations (1st line)	EU AI Act Art. 14 Human oversight *(Overlapping)* ✓ GDPR Art. 22 Automated decision-making *(Overlapping)* ✓ MAS FEAT Accountability principles *(Complementary)* ✓ NIST AI RMF MANAGE *(Complementary)* ✓
EV-07	HC-07 Accuracy, robustness and cybersecurity L2, L3 · weight 3	Performance and robustness test report	accuracy and adversarial test report	Model owner (1st line)	EU AI Act Art. 15 Accuracy, robustness, cybersecurity *(Equivalent)* ✓ NIST AI RMF MEASURE *(Overlapping)* ✓ FS AI RMF Security and resilience *(Overlapping)* ✓ NIST CSF 2.0 PROTECT / DETECT *(Complementary)* ✓
EV-08	HC-08 Fairness and bias testing L1, L2 · weight 3	Bias test report	all relevant groups each release	Model owner (1st line)	MAS FEAT Fairness principles *(Equivalent)* ✓ NIST AI RMF MEASURE (harmful bias) *(Overlapping)* ✓ EU AI Act Art. 10 Examination for bias *(Overlapping)* ✓
EV-09	HC-09 Independent model validation L2 · weight 2	Independent validation report	independent 2nd-line validation	Model risk management (2nd line)	SR 26-2 §III Effective challenge; §V Model validation *(Unique)* ✓ ISO/IEC 42001 Annex A.6 AI system life cycle *(Complementary)* * control area from a secondary listing (paid standard)
EV-10	HC-10 Access control for model and pipeline L2, L3 · weight 2	Access review and MFA configuration	MFA plus quarterly access review	IT security operations (1st line)	NIST CSF 2.0 PR.AA Identity Management, Authentication, and Access Control *(Equivalent)* ✓ GDPR Art. 32 Security of processing *(Overlapping)* ✓ FS AI RMF Access and security controls *(Overlapping)* ✓
EV-11	HC-11 Data-protection impact assessment L1 · weight 2	DPIA / FRIA document	approved DPIA	Data protection officer (2nd line)	GDPR Art. 35 DPIA *(Conditional)* ✓ EU AI Act Art. 27 Fundamental-rights impact assessment *(Conditional)* ✓
EV-12	HC-12 AI governance roles and accountability L1, L2, L3, L4 · weight 2	Model ownership register and RACI	named owner signed off	Chief risk officer (2nd line)	ISO/IEC 42001 Annex A.3 Internal organization *(Equivalent)* * control area from a secondary listing (paid standard) NIST AI RMF GOVERN *(Equivalent)* ✓ NIST CSF 2.0 GV.RR Roles, Responsibilities, and Authorities *(Overlapping)* ✓ MAS FEAT Accountability principles *(Overlapping)* ✓ FS AI RMF Governance and accountability *(Overlapping)* ✓

5. Test-case evidence states

A test case is one possible state of Bank S's evidence, from well governed to weakly governed. The expected result of every test case was fixed before the tool computed it. All 25 test cases pass in the tools (re-run on 24 October 2026): the 18 shown here plus C4's 7 accountability tests, which check the owner routing rather than an evidence state.

> Each component's test cases were built to test that component on its own. C1's TC1 and C3's TC1 are separate evidence states, not the same state of Bank S, so a document can be rated differently in each. One joint evidence state for all four components comes with integration.

5.1 C1 — four evidence states of the same system

Expected verdicts: TC1 Well-governed → **Approve** · TC2 Mostly governed → **Monitor** · TC3 Partially governed → **Restrict** · TC4 Weakly governed → **Reject**.

Code	Indicator	TC1 Well-governed	TC2 Mostly governed	TC3 Partially governed	TC4 Weakly governed
EP-01	Model documentation / model card exists	Full v2.1, complete and versioned	Full v2.1, complete and versioned	Partial v0.9, no limitations section	Absent No model documentation
EP-02	Training data sources & features disclosed	Full sources, 42 features and lineage documented	Full sources, 42 features and lineage documented	Full sources, 42 features and lineage documented	Partial sources listed, feature lineage missing
EP-03	Decision logic communicated to stakeholders	Full notice explains the key factors	Partial website says 'AI-assisted decisions' only	Partial website says 'AI-assisted decisions' only	Absent No disclosure that AI is used
EP-04	Each decision produces a reason/explanation	Full all 50 sampled outputs carry reason codes	Partial reasons only for declined cases	Partial reasons only for declined cases	Absent Outputs give a score only
EP-05	Explanation method is documented & validated	Full SHAP method report with validation results	Full SHAP method report with validation results	Partial SHAP named, no validation	Absent No method documented
EP-06	Adverse-action reasons given to customers	Full letter lists the top 3 specific reasons	Partial letter gives a generic reason	Absent Declined customers get no reason	Absent Declined customers get no reason
EP-07	A named role owns the model	Full Head of Credit Risk signed as owner	Full Head of Credit Risk signed as owner	Full Head of Credit Risk signed as owner	Partial owned by 'Analytics team'
EP-08	Human oversight / override process exists	Partial overrides allowed but not logged	Partial overrides allowed but not logged	Partial overrides allowed but not logged	Absent No human override
EP-09	Incident & escalation process defined	Full AI incident runbook with escalation path	Partial general IT incident process only	Partial general IT incident process only	Absent No incident process
EP-10	Decisions logged with model version & inputs	Full full log including inputs and model version	Full full log including inputs and model version	Partial outcomes logged, no model version	Absent Decisions are not logged
EP-11	Logs retained & tamper-evident per policy	Full retention policy plus write-once storage	Partial 7-year retention, logs editable	Partial 7-year retention, logs editable	Absent No retention policy
EP-12	Independent review / audit process exists	Partial self-review by the development team	Partial self-review by the development team	Partial self-review by the development team	Absent No review
EP-13	Bias testing across protected groups	Full gender, age and region tested each release	Partial gender tested once, at launch	Partial gender tested once, at launch	Absent Not tested for bias
EP-14	Fairness metrics & thresholds defined	Full approved thresholds (e.g. ratio ≥ 0.8)	Partial metric chosen, no threshold set	Partial metric chosen, no threshold set	Absent No fairness metric
EP-15	Remediation process for detected bias	Full tracked remediation log	Partial ad-hoc fix, undocumented	Partial ad-hoc fix, undocumented	Absent No remediation process
EP-16	Performance monitored for drift	Full monthly drift report with alerts	Full monthly drift report with alerts	Partial quarterly manual check	Absent No monitoring
EP-17	Adversarial / data-quality testing done	Partial input validation only	Partial input validation only	Partial input validation only	Partial input validation only
EP-18	Fallback / safe-mode on failure defined	Full tested fallback to manual underwriting	Partial manual fallback, never tested	Absent No fallback	Absent No fallback

5.2 C2 — threat ratings per deployment variant

Each cell gives likelihood (L) × impact (I) before controls, and the control strength that reduces likelihood. Expected bands: V1 Internal batch scoring → **Low** · V2 Branch officer tool → **Medium** · V3 Online customer application → **High** · V4 Chat assistant on third-party model → **Critical**.

Threat · source	V1 Internal batch scoring	V2 Branch officer tool	V3 Online customer application	V4 Chat assistant on third-party model
T01 Training-data poisoning L1 · AML.T0020 Poison Training Data	L2 × I3 control: Effective	L3 × I4 control: Partial	L4 × I4 control: Partial	L4 × I5 control: Absent
T02 Membership inference (training-data disclosure) L1 · AML.T0024.000 Infer Training Data Membership	not selected	not selected	L3 × I4 control: Partial	L4 × I4 control: Absent
T03 Upstream feed / data-pipeline compromise L1 · NIST AI 100-2 E2025	not selected	L4 × I4 control: Partial	L4 × I4 control: Partial	L4 × I4 control: Partial
T04 Model extraction / theft L2 · AML.T0024.002 Extract AI Model	not selected	not selected	L4 × I4 control: Partial	L4 × I4 control: Absent
T05 Model inversion L2 · AML.T0024.001 Invert AI Model	not selected	not selected	L3 × I4 control: Partial	L4 × I4 control: Absent
T06 Backdoor / trojan insertion L2 · AML.T0018 Manipulate AI Model	L1 × I3 control: Partial	L2 × I4 control: Partial	L2 × I4 control: Partial	L3 × I5 control: Absent
T07 Compromised vendor / pre-trained component L2 · AML.T0010 AI Supply Chain Compromise	not selected	not selected	L3 × I4 control: Partial	L4 × I5 control: Absent
T08 Evasion / adversarial input crafting L3 · AML.T0015 Evade AI Model	not selected	L4 × I4 control: Partial	L5 × I4 control: Partial	L5 × I4 control: Partial
T09 Prompt injection L3 · AML.T0051 LLM Prompt Injection · OWASP LLM01:2025 Prompt Injection	not selected	not selected	not selected	L5 × I4 control: Absent
T10 Abuse of integration credentials L3 · AML.T0012 Valid Accounts	not selected	not selected	L3 × I4 control: Partial	L4 × I4 control: Partial
T11 Confidence / explanation leakage L4 · NIST AI 100-2 E2025	not selected	not selected	L4 × I3 control: Partial	L5 × I4 control: Absent
T12 Output-integrity compromise in transit L4 · NIST AI 100-2 E2025	L2 × I3 control: Effective	L3 × I3 control: Partial	L3 × I4 control: Partial	L3 × I4 control: Partial
T13 Sensitive information disclosure by assistant L4 · OWASP LLM02:2025 Sensitive Information Disclosure	not selected	not selected	not selected	L4 × I5 control: Absent

5.3 C3 — control status per test case

Expected results: TC1 Well evidenced → **CCS 92.6%, 2 gaps** · TC2 Partly evidenced → **CCS 63%, 6 gaps** · TC3 Weakly evidenced → **CCS 22.2%, 11 gaps** · TC4 TC2 with EU in scope → **CCS 58.6%, 7 gaps**. TC4 uses the TC2 evidence with the EU market in scope.

Control	TC1 Well evidenced	TC2 Partly evidenced	TC3 Weakly evidenced	TC4 TC2 with EU in scope
HC-01 AI risk-management process	Met risk register reviewed and approved	Partially met risk register exists, not yet reviewed	Not met	Partially met risk register exists, not yet reviewed
HC-02 Training-data governance and quality	Met data sheet plus quality report	Met data sheet plus quality report	Partially met data sheet without quality checks	Met data sheet plus quality report
HC-03 Technical documentation and model inventory	Met complete model card, in inventory	Partially met model card missing limitations	Not met	Partially met model card missing limitations
HC-04 Decision logging and record-keeping	Met full decision log, retained	Partially met outcomes logged, no model version	Not met	Partially met outcomes logged, no model version
HC-05 Notice of AI use to customers	Partially met generic 'AI-assisted' statement	Met notice explains the key factors	Partially met generic 'AI-assisted' statement	Met notice explains the key factors
HC-06 Human oversight and right to contest	Met procedure, logged and reviewed	Partially met overrides allowed, not logged	Not met	Partially met overrides allowed, not logged
HC-07 Accuracy, robustness and cybersecurity	Met accuracy and adversarial test report	Met accuracy and adversarial test report	Partially met accuracy tested, no adversarial tests	Met accuracy and adversarial test report

Control	TC1 Well evidenced	TC2 Partly evidenced	TC3 Weakly evidenced	TC4 TC2 with EU in scope
HC-08 Fairness and bias testing	Met all relevant groups each release	Not met	Not met	Not met
HC-09 Independent model validation	Partially met self-review by developers	Not met	Not met	Not met
HC-10 Access control for model and pipeline	Met MFA plus quarterly access review	Met MFA plus quarterly access review	Partially met MFA on, no access review	Met MFA plus quarterly access review
HC-11 Data-protection impact assessment	Not applicable (EU-only sources, EU out of scope)	Not applicable (EU-only sources, EU out of scope)	Not applicable (EU-only sources, EU out of scope)	Not met
HC-12 AI governance roles and accountability	Met named owner signed off	Met named owner signed off	Partially met team named, no accountable role	Met named owner signed off

5.4 C4 — decision scenarios

Until integration, C4 receives these simulated outputs from C1–C3. Each finding names the control it is routed to.

Scenario	Inputs from C1–C3	Findings passed to C4 [severity → control]	Expected
S1 Strong on all three	CTI 92 · CREI 7 (Low) · CCS 93%	C2: T12 output-integrity in transit — residual 1×3 [Low → K10 Tamper-evident decision logging] C3: HC-09 independent validation partially met [Low → K11 Independent model validation] C3: HC-05 customer notice partially met [Low → K9 Reason codes and adverse-action explanations]	**Approve**
S2 Moderate	CTI 66 · CREI 28 (Medium) · CCS 63%	C1: Fairness 50/100 — bias tested once [Medium → K8 Bias testing across groups each release] C1: Explainability 67/100 — reasons for declines only [Medium → K9 Reason codes and adverse-action explanations] C1: Auditability 67/100 — two indicators only partly evidenced [Medium → K10 Tamper-evident decision logging] C2: T03 bureau-feed compromise — residual 3×4 [Medium → K3 Sanitise and verify training-data provenance] C3: HC-04 decision logging partially met [Medium → K10 Tamper-evident decision logging] C3: HC-08 fairness and bias testing not met [Medium → K8 Bias testing across groups each release] C3: HC-09 independent validation not met [Medium → K11 Independent model validation]	**Monitor**
S3 Trusted but exposed	CTI 90 · CREI 39 (High) · CCS 88%	C2: T08 evasion on online channel — residual 4×4 (C2 override OR-H) [High → K5 Validate inputs and detect adversarial inputs] C2: T04 model extraction via public API — residual 3×4 [Medium → K1 Rate-limit and monitor model queries] C2: T11 explanation leakage — residual 3×3 [Medium → K2 Return less detail in outputs] C3: HC-06 human oversight partially met [Low → K13 Human oversight and appeal procedure]	**Monitor**
S4 Hidden critical threat	CTI 82 · CREI 70 (Critical) · CCS 85%	C2: T01 poisoning, impact 5, no control (C2 override OR-C) [High → K3 Sanitise and verify training-data provenance] C2: T07 unverified third-party foundation model [High → K4 Verify vendor / pre-trained model artefacts] C2: T09 prompt injection on chat assistant [High → K6 Guardrails and input filtering on the assistant] C1: Robustness 67/100 — fallback never tested [Medium → K14 Drift monitoring with alert thresholds]	**Restrict**
S5 Compliance gap	CTI 78 · CREI 30 (Medium) · CCS 45%	C3: HC-06 human oversight and right to contest not met [High → K13 Human oversight and appeal procedure] C3: HC-09 independent validation not met [Medium → K11 Independent model validation] C3: HC-04 decision logging not met [Medium → K10 Tamper-evident decision logging] C3: HC-02 training-data governance partially met [Medium → K3 Sanitise and verify training-data provenance]	**Restrict**

Scenario	Inputs from C1–C3	Findings passed to C4 [severity → control]	Expected
S6 Weak on all three	CTI 8 · CREI 85 (Critical) · CCS 22%	C1: Explainability 0/100 — score only, no reasons [High → K9 Reason codes and adverse-action explanations] C1: Fairness 0/100 — never tested for bias [High → K8 Bias testing across groups each release] C1: Auditability 0/100 — decisions not logged [High → K10 Tamper-evident decision logging] C2: T01 poisoning, impact 5, no control [High → K3 Sanitise and verify training-data provenance] C3: HC-01 AI risk management not met [High → K15 AI risk register and named accountable owner] C3: HC-04 decision logging not met [High → K10 Tamper-evident decision logging] C3: HC-06 human oversight not met [High → K13 Human oversight and appeal procedure] C3: HC-08 fairness and bias testing not met [High → K8 Bias testing across groups each release]	**Reject**

6. Expert judgements — current status

No expert judgements have been collected yet. The values below let the tools run and are clearly labelled as placeholders inside each tool.

Where	What is needed	What the tool uses now	Status · plan
C1 dimension weights	AHP pairwise comparisons of the six trust dimensions	Five illustrative judgements per pair (15 pairs), used only to test the AHP calculation	Placeholder. To be replaced with responses from bank risk, audit and compliance practitioners; accepted only if CR < 0.10.
C2 context-factor weights	Two-round Delphi on the five context factors	Proposal defaults: Data sensitivity 0.25, Attack surface 0.22, Model exposure 0.2, Access exposure 0.18, Third-party & integration 0.15	Proposal defaults. Delphi rounds after PP1.
C3 control weights	Expert review of control importance	3 = high impact, 2 = standard (iteration 1)	Placeholder. Expert review and sensitivity analysis after PP1.
C4 criterion weights	AHP pairwise comparisons of trust, risk and compliance	Five illustrative judgements per pair (3 pairs), used only to test the calculation	Placeholder. Same expert panel as C1.
Whole pack	Is this system and its evidence realistic for a bank?	—	Included as a question in the expert review.

7. Limitations

- Bank S, its documents and every finding are invented. Results show that the method behaves as designed, not how any real bank performs.
- The evidence is described in summary form. The underlying documents (the model card, the bias report and so on) do not exist as separate files yet.
- Clause-level mappings show where a source asks for something similar. They are not legal advice and do not prove compliance.
- ISO/IEC 42001 text has not been read (paid standard). Sri Lankan sources are listed as context and are not yet mapped clause by clause.
- All weights are placeholders until the expert review (Section 6).

8. Source register

Every source below was checked online on **21 October 2026**. “What was checked” shows which parts were read, and “Status” shows how far each source has been verified.

Source (exact title, version, date)	Publisher	Where to get it	What was checked	Status
MITRE ATLAS, data release 5.6.0	MITRE	atlas.mitre.org · data file github.com/mitre-atlas/atlas-data (dist/ATLAS.yaml)	Names of AML.T0010, T0012, T0015, T0018 (+.000, .001), T0020, T0024.000–.002, T0051 and mitigations AML.M0002, M0004, M0007, M0014, M0015	Verified
Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (NIST AI 100-2 E2025), March 2025	NIST	csrc.nist.gov/pubs/ai/100/2/e2025/final · doi.org/10.6028/NIST.AI.100-2e2025	Title, number, date, DOI	Verified (taxonomy used at category level)
OWASP Top 10 for LLM Applications 2025	OWASP GenAI Security Project	genai.owasp.org/llm-top-10/	LLM01:2025 Prompt Injection; LLM02:2025 Sensitive Information Disclosure	Verified
Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, 26 January 2023	NIST	nist.gov/itl/ai-risk-management-framework · doi.org/10.6028/NIST.AI.100-1 · core text at airc.nist.gov	Functions GOVERN/MAP/MEASURE/MANAGE; subcategory text of GOVERN 2.1, MAP 1.1, MEASURE 2.5, 2.7, 2.9, 2.11, MANAGE 4.1	Verified
The NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29, 26 February 2024	NIST	csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final · doi.org/10.6028/NIST.CSWP.29	Title, number, date; category names GV.RR, PR.AA, PR.PS (from NIST’s CSF 2.0 core listing)	Verified
Principles to Promote Fairness, Ethics, Accountability and Transparency (FEAT) in the Use of AI and Data Analytics in Singapore’s Financial Sector, 12 Nov 2018 (para 1.4 updated 7 Feb 2019)	Monetary Authority of Singapore	mas.gov.sg/publications/monographs-or-information-paper/2018/FEAT (PDF: feat-principles-updated-7-feb-19.pdf)	Full text read; principles P1–P14 used as cited	Verified
Regulation (EU) 2024/1689 (Artificial Intelligence Act)	European Union	eur-lex.europa.eu/eli/reg/2024/1689/oj (read via artificialintelligenceact.eu)	Titles of Arts 9–15, 26, 27, 86; text of Art. 10(2)(f)–(g), 15(4)–(5), 26(6), 26(11), 86(1); Annex III 5(b)	Verified (secondary site mirrors the official text)
Regulation (EU) 2016/679 (General Data Protection Regulation)	European Union	eur-lex.europa.eu/eli/reg/2016/679/oj (read via gdpr-info.eu)	Titles of Arts 5, 13, 14, 22, 32, 35	Verified (secondary site mirrors the official text)
SR 26-2 Revised Guidance on Model Risk Management, 17 April 2026 (supersedes SR 11-7 of 4 April 2011)	Federal Reserve Board, OCC, FDIC	federalreserve.gov/supervisionreg/srletters/SR2602.pdf	Full text read: supersession, scope (excludes generative and agentic AI), effective challenge, validation, inventory, documentation, vendor models	Verified
Financial Services AI Risk Management Framework (FS AI RMF), released 19 February 2026	U.S. Department of the Treasury with the Cyber Risk Institute and FSSCC	home.treasury.gov/news/press-releases/sb0401 · cyberriskinstitute.org/artificial-intelligence-risk-management/	Title, release date, publishers; contents (adoption questionnaire, risk and control matrix of ~230 control objectives) from the publishers’ announcements	Partly verified (control matrix not read)
ISO/IEC 42001:2023 Artificial intelligence — Management system	ISO / IEC	iso.org/standard/42001 (paid)	Annex A control areas A.2–A.10 from a secondary listing (riskprofs.com). The tools now cite only these control areas (A.3, A.5, A.6, A.7), not clause numbers	Not verified against the standard text (paid standard)

Source (exact title, version, date)	Publisher	Where to get it	What was checked	Status
Three Lines Model — IIA Statement of Position, 8 July 2026 (replaces the 2020 paper "The IIA's Three Lines Model: An Update of the Three Lines of Defense")	The Institute of Internal Auditors	theiia.org/en/resources/statements-of-position/	Title, publication date, and that it supersedes the 2020 paper	Partly verified (text not read)
Banking Act Directions No. 16 of 2021 — Regulatory Framework on Technology Risk Management and Resilience for Licensed Banks (9 Dec 2021; amended by Directions No. 05 of 2023)	Central Bank of Sri Lanka	cbsl.gov.lk/sites/default/files/cbslweb_documents/laws/cdg/Banking_Act_Directions_No_16_of_2021.pdf	Title, date, scope from CBSL listing	Partly verified (text not mapped)
Personal Data Protection Act No. 9 of 2022 (amended by Act No. 22 of 2025)	Parliament of Sri Lanka	documents.gov.lk	Existence; commencement of parts is phased and sources disagree	Not verified (commencement dates not yet confirmed)
MITRE D3FEND	MITRE	d3fend.mitre.org	D3-MFA Multi-factor Authentication	Verified

9. Corrections made after checking the sources

Checking the sources on 21 October 2026 found eight out-of-date or imprecise references in the tools. All eight were corrected the same day. None changed a score: every test case was re-run afterwards and still passes.

#	Finding	Changed in	What was changed	Status
1	**SR 11-7 has been superseded** by SR 26-2 (17 April 2026). SR 26-2 also puts generative and agentic AI outside its scope, and says validation quality depends on rigour rather than on organisational structure.	C3 HC-01, HC-03, HC-04, HC-09; C4 control K11	Source renamed to SR 26-2 (Fed/OCC/FDIC). Links now cite §VI Governance and controls, §VI Model inventory and Documentation, and for HC-09 §III Effective challenge and §V Model validation. K11 cites SR 26-2 §V. SR 26-2 does not cover the V4 chat assistant (generative AI).	Applied
2	**MITRE ATLAS renamed "ML" to "AI".** IDs are unchanged.	C4 K1, K2, K4; C2 footer	K1 AML.M0004 Restrict Number of AI Model Queries; K2 AML.M0002 Passive AI Output Obfuscation; K4 AML.M0014 Verify AI Artifacts. C2 footer records ATLAS release 5.6.0 and that T06 maps to AML.T0018 Manipulate AI Model.	Applied
3	**EU AI Act Art. 13 is about information to deployers**, not to customers.	C3 HC-05	Link now cites Art. 26(11) (informing affected persons) and Art. 86 (right to explanation).	Applied
4	**NIST CSF 2.0 category names were shortened.**	C3 HC-10, HC-12	Full names used: PR.AA Identity Management, Authentication, and Access Control; GV.RR Roles, Responsibilities, and Authorities.	Applied
5	**FS AI RMF publisher** is the U.S. Treasury together with the Cyber Risk Institute and FSSCC (released 19 Feb 2026).	C3 source list	Source named "FS AI RMF (US Treasury, Cyber Risk Institute and FSSCC, 2026)".	Applied
6	**OWASP references needed the edition year.**	C2 T09, T13; C4 K6	Now LLM01:2025 and LLM02:2025. An unverified D3FEND reference on K6 was removed; K7 now cites D3FEND D3-MFA.	Applied
7	**ISO/IEC 42001 clause numbers could not be verified** (paid standard).	C1 Accountability, Auditability; C3 HC-01, HC-09, HC-12	Clause numbers replaced with Annex A control areas: HC-01 A.5 Assessing impacts of AI systems; HC-09 A.6 AI system life cycle; HC-12 A.3 Internal organization; C1 Accountability A.3. C1 Auditability now cites EU AI Act Art. 12.	Applied (not yet checked against the standard text)

#	Finding	Changed in	What was changed	Status
8	**The IIA 2020 Three Lines paper is superseded** by the IIA Statement of Position “Three Lines Model” (8 July 2026).	C1 Accountability; C4 footer	Both now cite the IIA Three Lines Model (2026). The tools keep the proposal’s term “Three Lines of Defense” in their labels.	Applied